

# ДокПоток

Единая входящая ЭДО для группы компаний

Проектная работа курса «Разработка с AI-агентами»  
Анастасия Топчий · октябрь 2026

[topchiiaa-eng.github.io/docflow](https://topchiiaa-eng.github.io/docflow) · [github.com/topchiiaa-eng/docflow](https://github.com/topchiiaa-eng/docflow)

ДокПоток

Выйти

Входящие

На  
подпись

Журнал

Организац

Входящие

+ Добавить документ

1

новых документов

2

требуют подписи

214 300 Р

сумма входящих

Все организации

▼

Все статусы

▼

Поиск: контраге

УПД № 260810/54 · ООО «ГетБ...

89 800 Р

Компания А · 01.10 17:57

Подписан

Акт сверки № 809 · ООО «ВебсайтСо...

—

Компания Б · 01.10 16:57

Требуется подпись

# Проблема: один менеджер — N ящиков ЭДО

## 20–30

минут в день уходит на обход ящиков трёх юриц в Контур.Диадоке (замер на собственной практике)

## ДНИ

задержка, с которой замечают документ «требуется подпись» — и срыв сроков документооборота



### Кто страдает

Операционные менеджеры и бухгалтеры малых групп компаний (2–10 юриц): один человек ведёт документооборот нескольких ООО



### Почему так

Интерфейсы ЭДО рассчитаны на «одна организация — один ящик»; несколько юриц = переключение контекста



### Что было до проекта

Telegram-бот (ДЗ-2): уведомления есть, рабочего места нет — ни фильтров, ни истории, ни очереди на подпись



### Цель

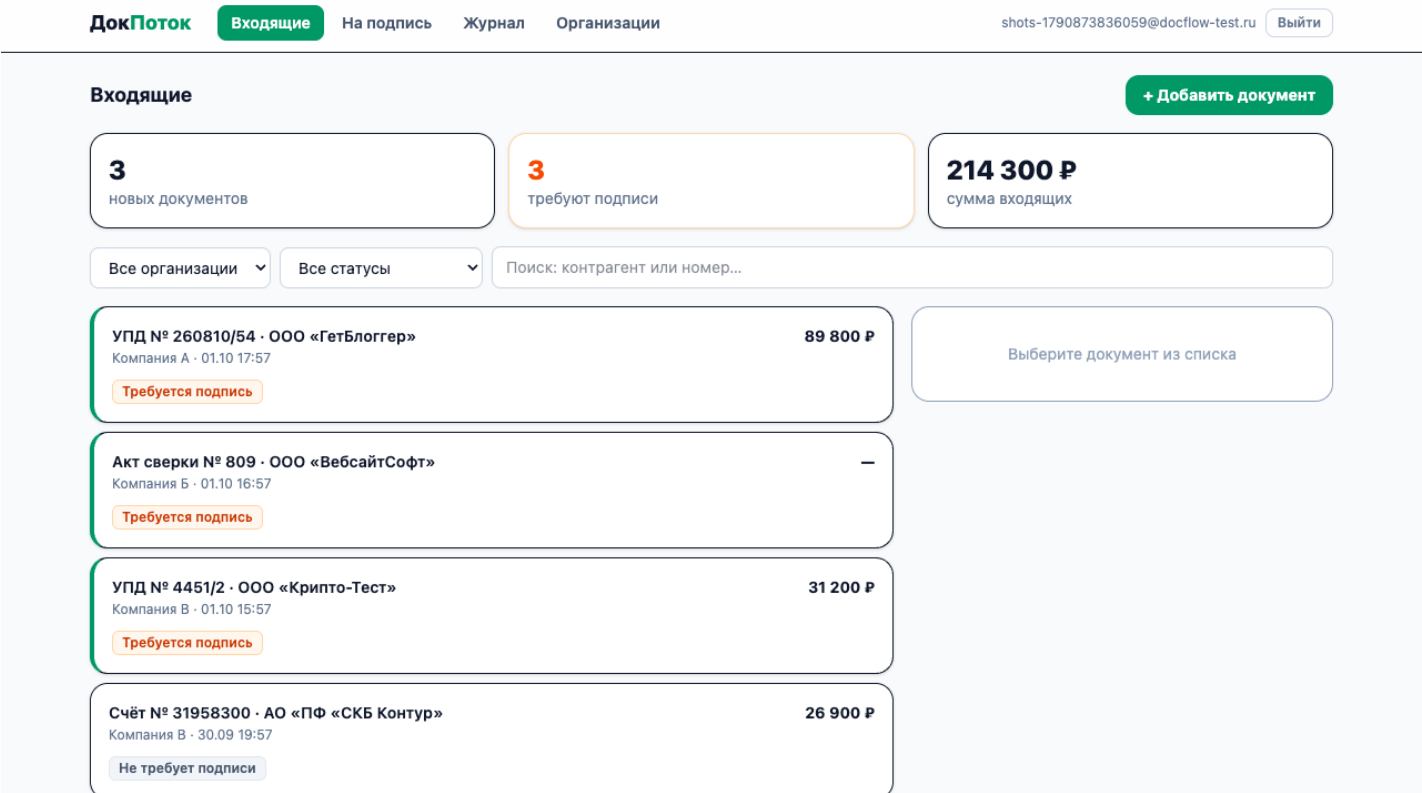
Один экран на все организации: лента, очередь «на подпись» с явным подтверждением, журнал, роли

# Конкуренты: «несколько юрлиц» = переключатель, а не лента

| Продукт                      | Несколько организаций                                                                 | Роли и подписание                                                                                        |
|------------------------------|---------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------|
| Контур.Диадок                | Одна учётка → список организаций → переключение контекста. Единой ленты нет           | Админ / редактор / читатель; маршруты согласования и «доп. подпись» — платные модули (10–230 тыс. ₽/год) |
| СБИС / Saby                  | Несколько компаний в аккаунте, тариф — на каждую; при отправке выбирается организация | Простое согласование в тарифе, маршруты — отдельная лицензия                                             |
| 1С-ЭДО (многофирменный учёт) | «Текущие дела ЭДО» — общий список по базе 1С; нужна 1С у каждого пользователя         | Маршруты подписания несколькими сертификатами                                                            |
| DocuSign / PandaDoc          | Switch Account / Workspaces (Enterprise) — изоляция, без общей входящей               | Роли по аккаунту / workspace                                                                             |
| Dext / Hubdoc (бухфирмы)     | Ближайший паттерн: панель фирмы, очередь документов по каждому клиенту                | Без юридически значимой подписи                                                                          |

Ниша: единая кросс-организационная лента + очередь «на подпись» по ролям + журнал. Главный риск — зависимость от API одного провайдера → абстракция EdoProvider в архитектуре. Анализ выполнен AI-агентом с веб-поиском (docs/competitors.md).

# Решение: четыре экрана + вход



1

## Входящие

Лента всех организаций, KPI, фильтры, поиск, карточка документа, добавление с PDF

2

## На подпись

Очередь «требуется подпись» → диалог подтверждения → подписание по роли

3

## Журнал

Append-only журнал: успехи и отказы с причиной

4

## Организации

Создание, переименование, удаление; участники по email, роли

Адаптивно:  $\geq 1024\text{px}$  — master-detail, на мобильных карточка открывается поверх списка. Каждый экран: loading / error / empty / success.

# Организации и журнал подписаний

ДокПоток

Входящие

На подпись

Журнал

Организации

shots-1790873836059@docflow-test.ru

Выйти

Организации

Название новой организации (например, ООО «Ромашка»)

+ Создать

Компания А

Ваша роль: Подписант · владделец

shots-1790873836059@docflow-test.ru

Подписант

email зарегистрированного пользоват€

Оператор

Добавить

Компания Б

Ваша роль: Подписант · владделец

Показать участников

Компания В

Ваша роль: Оператор

Показать участников

CRUD организаций; участники добавляются по email через RPC (auth.users клиенту недоступна); роль «оператор» без права подписи — для живой проверки политик

ДокПоток

Входящие

На подпись

Журнал

Организации

shots-1790873836059@docflow-test.ru

Выйти

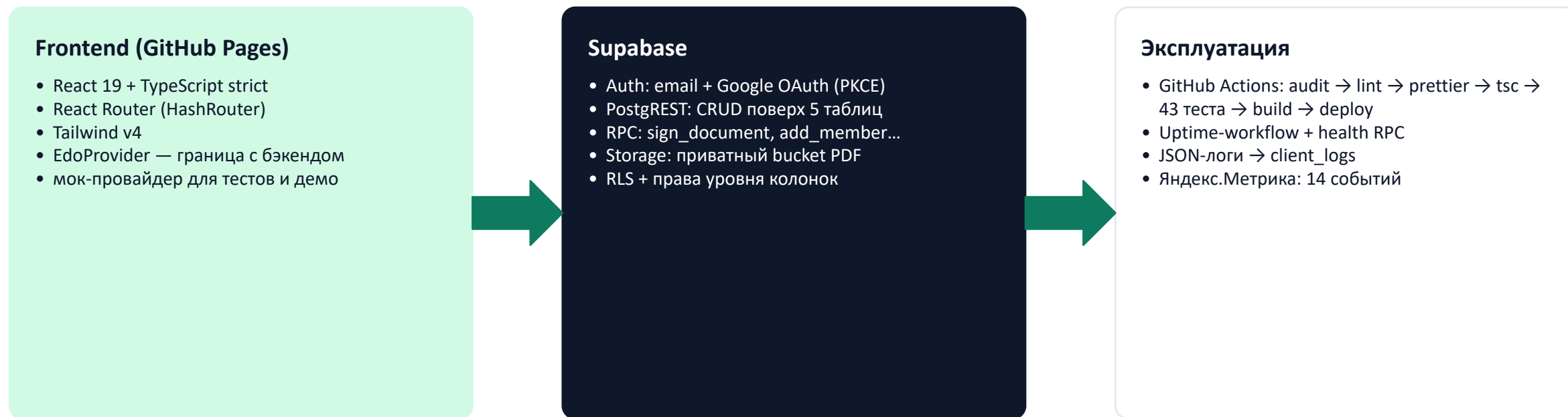
Журнал подписаний

☐ Только отказы (1)

| КОГДА       | ДОКУМЕНТ        | КОНТРАГЕНТ        | ОРГАНИЗАЦИЯ | РЕЗУЛЬТАТ                     |
|-------------|-----------------|-------------------|-------------|-------------------------------|
| 01.10 19:57 | УПД № 4451/2    | ООО «Крипто-Тест» | Компания В  | Отказ: роль без права подписи |
| 01.10 19:57 | УПД № 260810/54 | ООО «ГетБлоггер»  | Компания А  | Подписан                      |

Журнал пишется только сервером (RPC), клиент не может его менять; отказы фиксируются с причиной — «роль без права подписи», «документ не требует подписи»

# Архитектура



Ключевое решение: интерфейс EdoProvider. Фронтенд не знает, откуда данные — бэкенд подключался без изменения компонентов; тот же интерфейс закрывает риск зависимости от одного ЭДО-провайдера.

*Нет прав администратора на машине → нет Docker/VPS → Supabase + GitHub Pages: ограничение стало фильтром решений.*

# Данные и безопасность

| Таблица       | Назначение                                              |
|---------------|---------------------------------------------------------|
| organizations | юрлица; created_by — владелец                           |
| org_members   | роли: signer / operator / accountant (M:N с auth.users) |
| documents     | входящие; file_path → Storage; check-constraints        |
| sign_attempts | append-only журнал подписаний                           |
| client_logs   | warn/error с фронта                                     |

6 миграций в supabase/migrations — проверены на живой базе API-тестами и e2e под свежим пользователем.



## Подписание

Только через RPC с проверкой роли и статуса; у клиента отозваны права менять status — путь «мимо» физически невозможен



## RLS везде

Видимость только своих организаций; анонимам — 401; is\_member() как security definer против рекурсии



## Аудит OWASP (AI)

12 находок, 11 исправлены: служебная функция была вызываема через RPC, TOCTOU в подписании, утечка сообщений сервера, CSP



## Секреты

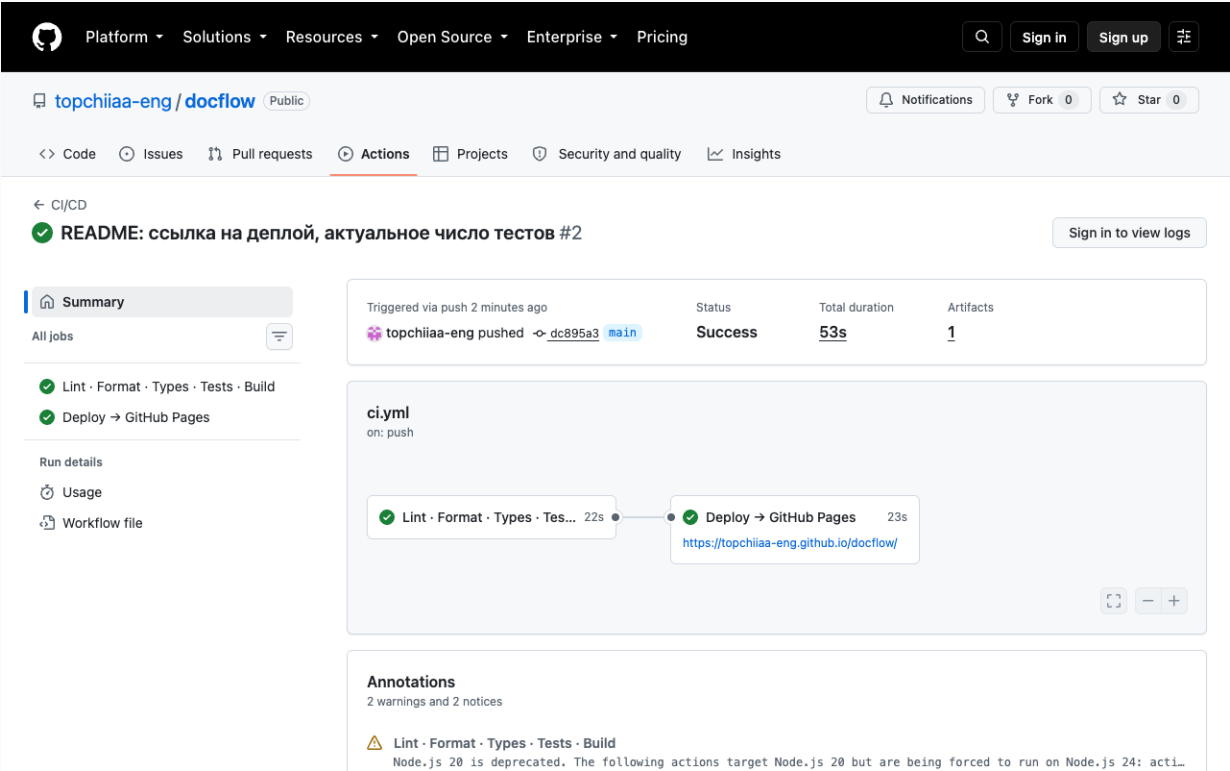
Ключи только в .env.local и GitHub Secrets; пароли тестовых учёток ротированы и убраны из репозитория

# AI-агент на каждом этапе

| Этап         | Как использован                                                                             | Что дало                                                           |
|--------------|---------------------------------------------------------------------------------------------|--------------------------------------------------------------------|
| Планирование | Идея, анализ конкурентов (субагент + веб-поиск), 3 UI-концепции text-to-UI, 12 user stories | Подтверждённая ниша; концепция выбрана по главному сценарию        |
| Архитектура  | Схема БД и RLS по ТЗ; ТЗ проверено независимым агентом-«техлидом»                           | 5 критичных пробелов в ТЗ найдены до первой строки кода            |
| Frontend     | Инициализация, компоненты по RTCF-промтам, тесты                                            | Баг «бесконечный цикл» найден по скриншоту + консоли               |
| Backend      | Миграции, RPC, Storage-политики; разбор ошибок PostgreSQL                                   | 5 багов, не видимых локально, пойманы на живой базе                |
| DevOps       | Генерация CI/CD и uptime-workflow, аудит OWASP независимым агентом                          | Пайплайн дважды остановил деплой по делу                           |
| Оптимизация  | Рекомендации линтера/агента: чанки, хуки, отмена устаревших ответов                         | Меньше лишних перерисовок; supabase-js кэшируется отдельно от кода |

Правила проекта (CLAUDE.md) влияли на архитектуру, а не на форматирование: из «подписание только через диалог» вырос RPC с проверкой роли на уровне БД.

# Качество: CI/CD, тесты, мониторинг



43

тестов: юниты, компоненты, провайдер

10

API-запросов к живой базе, 5 негативных

6

е2е-сценариев puppeteer на production

30 мин

интервал uptime-проверки + алерт

Пайплайн: npm audit → oxlint (0 предупреждений) → prettier → tsc → vitest → build → GitHub Pages → smoke-check. Дважды остановил деплой по делу: не включённый Pages и правки файлов в обход форматтера.

# Пять багов, которые не видели зелёные тесты



## Бесконечный цикл загрузки

Дефолт пропа создавал новый провайдер на каждый рендер. Найдено по скриншоту + консоли браузера; 12 тестов молчали — они передавали стабильный проп.



## Кириллица испорчена, миграция «Success»

рбсору без UTF-8-локали. Найдено сравнением repr() строк из API. Урок: после миграции читать данные обратно.



## Отказы не попадали в журнал

raise exception в plpgsql откатывал insert. RPC теперь возвращает {ok, error}. Урок: проверять побочные эффекты негативных сценариев.



## RLS отклоняла создание организации

INSERT ... RETURNING проверяется до AFTER-триггера членства. Нашёл только e2e на живой базе — мок и 43 теста не имеют RLS.



## Новый пользователь — пустое приложение

Триггер владельца (миграция 4) × «не ронять регистрацию» (аудит): ошибка сидинга проглатывалась. Поймал скрипт скриншотов под свежим пользователем.



## Общий вывод

«Зелёный прогон» ≠ «работает». Проверять данные и побочные эффекты другим инструментом — и сценарий «с нуля» после каждой миграции.

# Что я поняла о разработке с AI

1

**Агент сильнее всего, когда его проверяет другой агент**

Лучшие находки — независимое ревью ТЗ, независимый аудит безопасности, API-тесты против живой базы

2

**Правила влияют на архитектуру**

CLAUDE.md «чистая логика без сети» → тестируемые модули; «подписание через диалог» → RPC на уровне БД

3

**Жёсткие ограничения — лучший фильтр**

Нет sudo → Supabase, GitHub Pages, системный Chrome для e2e — каждое решение оказалось проще альтернатив

4

**Абстракция над провайдером окупилась дважды**

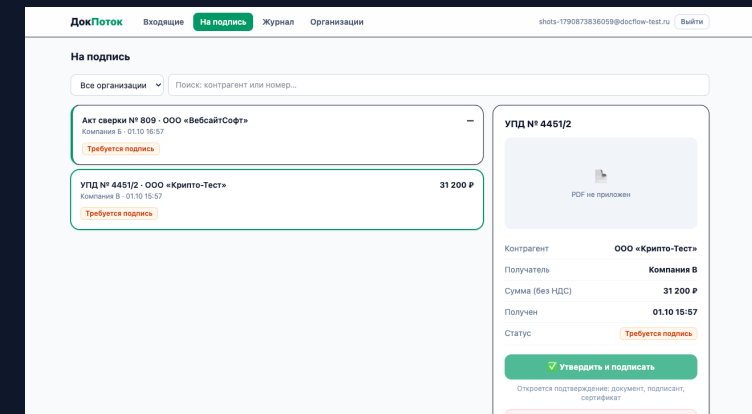
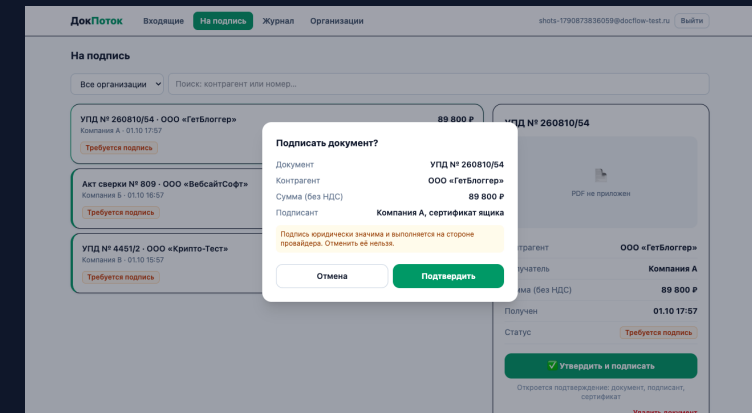
Мок для тестов и CI без секретов + ответ на главный рыночный риск

# Итоги

- 4 экрана, адаптивная вёрстка, формы с валидацией, 4 состояния экрана
- 5 связанных таблиц, полный CRUD, RLS, RPC, Storage, OAuth2, аналитика
- CI/CD → GitHub Pages, мониторинг, JSON-логи, аудит безопасности
- AI на всех этапах — задокументировано с промптами и результатами
- 43 теста, 10 API-тестов, 6 e2e-сценариев; 5 багов найдены только на живой базе и исправлены

Приложение: [topchiiaa-eng.github.io/docflow](https://topchiiaa-eng.github.io/docflow)

Код и документация: [github.com/topchiiaa-eng/docflow](https://github.com/topchiiaa-eng/docflow)



Спасибо! Вопросы?